REFERENCE · CHAPTER 9

Model Armor, Canonical Normalization & Cloud SDP Surrogate Tokenization

Defense-in-depth screening for inbound user prompts and outbound/inbound MCP database tool payloads.

1. Three-Layer Content Protection: Normalize, Screen (Fail-Closed), and De-identify

Content screening is a **probabilistic mitigation** that backs up our deterministic boundaries (`tools.yaml`, `FORCE RLS`, and HITL gates). To prevent attackers from bypassing screening via Unicode tag characters or Base64 encoding inside database text columns, we combine gateway-level Model Armor with canonical normalization and Cloud Sensitive Data Protection (SDP).

INSPECTION POINT	COMPONENT	WHAT IT CATCHES	FAILURE MODE PREVENTION
1. Ingress Edge	Ingress Agent Gateway / ALB Service Extension → **Model Armor**	Direct prompt injection (`T1`), jailbreaks, malicious URLs, and sensitive data in user prompts.	Blocks adversarial prompts before the agent container or LLM is invoked.
2. Egress / Tool Return	Egress Agent Gateway (`/mcp`, `/a2a/`) + ADK `after_tool_callback` (`normalize()`)	Indirect prompt injection (`T2`) hidden inside database rows (`delivery_notes`, support tickets), including NFKC homoglyphs, zero-width tags, and Base64 runs.	Fails closed unless `invocation_result == SUCCESS` and `filter_match_state == NO_MATCH_FOUND`.
3. Free-Text PII Boundary	**Cloud Sensitive Data Protection (SDP)** (`CryptoDeterministicConfig`)	Raw SSNs, credit cards, phone numbers, and emails embedded inside unstructured database notes (`LLM02`).	Replaces raw PII with deterministic surrogate tokens (keep payload `< 0.5 MB` per call) so the model never sees raw identifiers.